

FUN.XYZ · SECURITY REVIEW

Fun.xyz OFT Review.

A security review of OFT Review.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
Fun.xyz	OFT Review	Guardian	November 5 – November 6, 2025	November 14, 2025

§ 00

Contents.

22 pages — overview, confidence ranking, scope, 12 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 12 findings	P. 08
§ 05	Disclaimer	P. 21
§ 06	About Guardian	P. 22

§ 01

Overview.

Guardian reviewed OFT Review across a single review round. The final report includes 1 Critical, 2 High, 2 Medium, 5 Low, 2 Informational findings.

AUDIT FIRM	REPOSITORY
Guardian	fun-xyz/fun-contracts
CLIENT	METHODOLOGY
Fun.xyz	Smart contract · Manual · Main Review
PROJECT	MAIN REVIEW COMMIT
OFT Review	01d497797340
PREPARED BY	
Guardian	
AUDIT WINDOW	
November 5 – November 6, 2025	
FINAL REPORT	
November 14, 2025	

1.1 Confidence Ranking

3 / 5

Moderate Confidence

Guardian assigns a Confidence Ranking of 3 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
■ Critical	1	0	0	0	1
■ High	2	0	0	0	2
■ Medium	2	0	1	0	1
■ Low	5	0	5	0	0
■ Informational	2	0	2	0	0
All severities	12	0	8	0	4

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence ASSIGNED	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed OFT Review in `fun-xyz/fun-contracts`. The scope includes 86 source lines across 1 file.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW

Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
src/OFT/Fun0appComposer.sol	86	132

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
C-01	All In-Flight Assets Stolen	Logical Error	CRITICAL	RESOLVED	p. 8
H-01	Composer Allows Griefing Ethereal	DoS	HIGH	RESOLVED	p. 9
H-02	Open VaultDepositooor Allows Griefing	Access Control	HIGH	RESOLVED	p. 10
M-01	Unnecessary Nonce Check DoS	Superfluous Code	MEDIUM	RESOLVED	p. 11
M-02	Users Or Other Delegate Depositors Can DoS	DoS	MEDIUM	ACKNOWLEDGED	p. 12
L-01	User's Funds Stuck Due To Errant Encoding	DoS	LOW	ACKNOWLEDGED	p. 13
L-02	Only One DepositOnBehalfRequest Should Be Made	Warning	LOW	ACKNOWLEDGED	p. 14
L-03	Deposits Can Be DoS'd At Cap	DoS	LOW	ACKNOWLEDGED	p. 15
L-04	General Calldata Warning	Warning	LOW	ACKNOWLEDGED	p. 16
L-05	Refund Is Lost	Rounding	LOW	ACKNOWLEDGED	p. 18
I-01	Missing Zero Address Checks	Best Practices	INFORMATIONAL	ACKNOWLEDGED	p. 19
I-02	Outdated NatSpec	Documentation	INFORMATIONAL	ACKNOWLEDGED	p. 20

CRITICAL **C-01**

RESOLVED

All In-Flight Assets Stolen

CATEGORY	Logical Error
LOCATION	Fun0appComposer.sol
REVIEW	Main Review

DESCRIPTION

In the `Fun0AppComposer` contract `lzCompose` function there are several cases where the `to` address is allowed to be any arbitrary contract, along with any arbitrary calldata:

```
(bool success, bytes memory data) = address(_to).call(_callData);
```

The composer has a case to handle ERC20 OFTs which means it will have a nonzero balance for these ERC20 OFTs when they have been delivered but not yet had their composed message executed.

The arbitrary call to an arbitrary address however allows all ERC20 tokens sitting in the Composer to be stolen. This occurs when a malicious actor provides the token address as the `to` and provides the calldata of `approve(...)` to approve themselves to spend the entire composer contract's balance.

RECOMMENDATION

Consider removing the support of ERC20 OFTs and also removing all calls where the `to` address is not explicitly the `composerConfig.VaultWrapper`.

RESOLUTION

Status: Resolved.

HIGH **H-01**

RESOLVED

Composer Allows Griefing Ethereum

CATEGORY	DoS
LOCATION	Global
REVIEW	Main Review

— DESCRIPTION

As mentioned in L-04, there is a griefing vector where the composer is trusting that other delegate depositors do not instantiate alternate subaccounts for the user as this would DoS the composed message for eternity, trapping user funds.

However the FunOAppComposer contract could itself be used to grief accounts in this way. This is because the composed message is what provides the arbitrary calldata which will hold the details of which subaccount and account to deposit into. Any malicious actor could create a composed message that routes through the FunOappComposer system and depositOnBehalf's a dust amount of USDe for an unsuspecting account who also has an in-flight compose message.

Execution of compose messages is permissionless, so it is easily possible that a malicious actor could execute theirs through the LZ EndpointV2 contract before the user's honest depositOnBehalf action is executed, thus trapping their cross-chain deposit amounts forever.

— RECOMMENDATION

Consider requiring that the compose message also includes a signature, which validates that the compose message provided is indeed attested for by the account that is being deposited on behalf of. This signature will include attestation for the subaccount, deposit amount, and deposit token so there is no way to DoS the user's lzCompose by making the same deposit.

— RESOLUTION

Status: Resolved.

HIGH **H-02**

RESOLVED

Open VaultDepositoor Allows Griefing

CATEGORY	Access Control
LOCATION	VaultDepositoor
REVIEW	Main Review

DESCRIPTION

Ethereal requires that only whitelisted delegate depositors can invoke the depositOnBehalf function because there is a risky griefing vector associated with it, whereby a user can DoS the depositOnBehalf flow for an account by registering an unexpected subaccount before the user's cross-chain depositOnBehalf is completed.

The VaultDepositoor contract will be whitelisted for the delegate depositor permission on Ethereum, and also contains a permissionless deposit function which opens this access up to anyone, with arbitrary calldata going to the depositOnBehalf function.

RECOMMENDATION

Make the `VaultDepositoor` deposit function whitelisted so that only the composer contract can invoke it.

RESOLUTION

Status: Resolved.

MEDIUM **M-01**

RESOLVED

Unnecessary Nonce Check DoS

CATEGORY Superfluous Code
LOCATION Fun0appComposer.sol
REVIEW Main Review

DESCRIPTION

Now included in the composeMsg is a nonce value, however this nonce value and the associated check are not necessary as they don't prevent any kind of replay attack as there is no longer any signature of the composeMsg.

This nonce check in fact creates opportunities for user's to have their funds trapped by accidentally using the same nonce in the composeMsg.

RECOMMENDATION

Remove all associated nonce logic.

RESOLUTION

Status: Resolved.

MEDIUM **M-02**

ACKNOWLEDGED

Users Or Other Delegate Depositors Can DoS

CATEGORY	DoS
LOCATION	Global
REVIEW	Main Review

— DESCRIPTION

The depositOnBehalf function is not allowed when the account has not registered the corresponding subaccount and the account itself has already been initialized.

In other words, if the account already has a separate subaccount that is active, the deposit is not allowed.

This can cause the lzCompose action to be DoS'd in the case where the user creates a deposit for a different subaccount themselves, or another delegateDepositor creates a separate subaccount for the user before the lzCompose action is executed.

In this scenario, the user's funds in the cross-chain bridge would be permanently trapped.

— RECOMMENDATION

Understand that you are trusting the other whitelisted delegate depositors to not DoS the lzCompose actions this way, and warn users that they should never make a direct deposit to Ethereum before their bridge and lzCompose action is completed.

— RESOLUTION

Status: Acknowledged.

LOW **L-01**

ACKNOWLEDGED

User's Funds Stuck Due To Errant Encoding

CATEGORY DoS
LOCATION Fun0AppComposer.sol
REVIEW Main Review

DESCRIPTION

In the `lzCompose` function the application requires that the provided `_amount` inside the user specified `_message` composed message is exactly equal to the OFT amount that was sent and is recorded as a part of the base `composeMsg` in `OFTComposeMsgCodec.amountLD(_message)`.

However if an amount that is different than the exact transferred amount is errantly supplied, this will cause the compose execution to fail and the users funds to then be trapped in the composer.

RECOMMENDATION

Consider removing the ability to even specify the redundant `_amount` value in the composed message contents and simply rely on the `OFTComposeMsgCodec.amountLD(_message)` as the single source of truth.

RESOLUTION

Status: Acknowledged.

LOW **L-02**

ACKNOWLEDGED

Only One DepositOnBehalfRequest Should Be Made

CATEGORY	Warning
LOCATION	Global
REVIEW	Main Review

DESCRIPTION

The Ethereum `depositOnBehalf` function accepts a list of `DepositOnBehalfRequest` objects to initiate multiple `depositOnBehalf` actions.

However multiple request objects is incompatible with the VaultDepositooor system as it only replaces the first instance of the `AMOUNT_PLACEHOLDER` in the provided call data.

RECOMMENDATION

Ensure that in the frontend and all flows routing through the `Fun0appComposer` that only one such `DepositOnBehalfRequest` entry is used.

RESOLUTION

Status: Acknowledged.

LOW **L-03**

ACKNOWLEDGED

Deposits Can Be DoS'd At Cap

CATEGORY	DoS
LOCATION	Global
REVIEW	Main Review

— DESCRIPTION

The Ethereum system has a cap for deposits of any particular asset, for which only USDe is enabled at the moment.

This means that a deposit through the Fun system that would put the Ethereum system right at the cap, or at least near it, could be DoS'd by sending a small amount of native tokens directly to the Depositooor contract right before the lzCompose action is called.

The lzCompose message would then be stuck until that additional balance in the Depositooor contract is cleared.

— RECOMMENDATION

Simply be aware of this issue, it is unlikely that such a cap will be reached with a Fun deposit and that a user would grief the system like this.

— RESOLUTION

Status: Acknowledged.

LOW **L-04**

ACKNOWLEDGED

General Calldata Warning

CATEGORY	Warning
LOCATION	Global
REVIEW	Main Review

DESCRIPTION

In any IzComposer it is adamant that the call data provided is correctly formatted and contains accurate data. If anything causes a revert in the decoding, or application of the call data — whether that be in the composer contract or the downstream Ethereum contracts, this will permanently trap user funds in the composer contract.

Furthermore, no rescue functions should be added, since for some errors they may only be temporary, and if you were to rescue funds it would then allow users to steal assets from other bridges once their IzCompose message does become executable.

RECOMMENDATION

Be extremely cautious about the call data that is provided to the system, it should not trigger any of the revert cases that Ethereum holds in its depositOnBehalf flow such as the following amongst several others:

```
uint256 depositsLength = deposits.length;
if (depositsLength == 0) {
    revert ZeroLength();
}
uint16 batchSize = Exchange.load().delegateDepositMaxBatchSize;
if (depositsLength > batchSize) {
    revert DepositOnBehalfBatchSizeExceeded(batchSize);
}
ICollateralManager.DepositOnBehalfRequest calldata d = deposits[i];
if (d.tokenName != USD_TOKEN_NAME) {
    revert InvalidDepositOnBehalf(msg.sender, d.account, d.subaccount, "INVALID_TOKEN");
}
if (d.account == address(0)) {
    revert ZeroAddress();
}
if (amount == 0) {
```

L-04 General Calldata Warning

CONTINUED

```
revert ZeroAmount();
}
if (subaccount == bytes32(0)) {
revert ZeroLength();
}
if (depositToken == address(0)) {
revert InvalidDepositToken(depositToken);
}
```

— RESOLUTION

Status: Acknowledged.

LOW **L-05**

ACKNOWLEDGED

Refund Is Lost

CATEGORY Rounding
LOCATION Global
REVIEW Main Review

DESCRIPTION

The `depositOnBehalf` function may refund a dust amount back to the `Fun0appComposer` but no logic is implemented to sweep it. These funds are therefore locked in the contract and accumulate over time.

RECOMMENDATION

Be aware about this behavior and consider to document it.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-01**

ACKNOWLEDGED

Missing Zero Address Checks

CATEGORY Best Practices

LOCATION <https://github.com/GuardianOrg/fun-contracts-team1-1762356632009/blob/7e07c3981d368475190893a580188d9fb50a3877/src/OFT/Fun0appComposer.sol#L161>

REVIEW Main Review

DESCRIPTION

The `constructor` of the `Fun0appComposer` contract saves the given `composerConfig` without performing zero address checks.

RECOMMENDATION

Consider to perform zero address checks to follow best practices.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-02**

ACKNOWLEDGED

Outdated NatSpec

CATEGORY Documentation
LOCATION Fun0appComposer.sol
REVIEW Main Review

DESCRIPTION

The NatSpec for the constructor still references the VaultWrapper contract, however this is no longer used in the contract flow.

RECOMMENDATION

Update the NatSpec throughout the composer contract.

RESOLUTION

Status: Acknowledged.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.